Cyber Incident Response Plan
FinSecure Ltd

Phishing-Based Credential Compromise Scenario

Pruthviraj Patil

21/04/2026

Contents

Executive Summary 4
Organisation Overview 4
Purpose & Scope 5
  Purpose 5
  Scope 5
Definitions & Incident Classification 6
  Key Definitions 6
  Incident Classification Levels 6
Incident Response Team (Roles & Responsibilities) 7
  Incident Response Team Structure 7
  Roles & Responsibilities Overview 8
  Escalation and Coordination 8
Incident Scenario Description 9
  Phishing Attack Leading to Credential Compromise 9
Incident Detection & Identification 9
Incident Analysis 10
Incident Response Process 11
  Containment 11
  Eradication 11
  Recovery 12
  Post-Incident Actions 12
Impact Assessment (Confidentiality, Integrity, Availability) 13
Incident Timeline 14
Communication Plan 15
  Communication Objectives 15

Internal Communication 15
External Communication 15
Communication Control and Governance 16
Risk Mapping and Alignment 16
Risk Alignment 16
Control Gap Mapping 16
Risk and Incident Integration 17
Continuous Improvement 17
Recommendations and Control Improvements 18
Improving Authentication Measures 18
Increasing Security Awareness among Users 18
Monitoring and Detection Enhancements 18
Enhancing the Incident Response and Governance 18
Continuous Improvement and Risk Management 18
Lessons Learned 19
Compliance & Framework Alignment 20
ISO/IEC 27001 20
NIST Incident Response Lifecycle 20
General Data Protection Regulation (GDPR) 20
Summary 20
Appendices 21
Appendix A – Incident Log Template 21
Appendix B – Evidence Register 21
Appendix C – Incident Response Checklist 22

Executive Summary

This document offers an example of a structured Cyber Incident Response Plan for FinSecure Ltd. The purpose of this document is to demonstrate an actionable approach towards handling cyber incidents related to phishing and other relevant issues at FinSecure Ltd.

The goal of developing this response plan is to identify, manage, and mitigate risks associated with any kind of security event in an efficient, controlled manner while avoiding further damage or loss for the company.

Phishing and credential compromise represent one of the highest risks associated with information security at FinSecure Ltd. These events may result in unauthorized access to personal and/or financial information stored by FinSecure Ltd, putting the security of clients' data at risk.

Considering that FinSecure Ltd is focused on offering cloud-based fintech solutions and that the data being handled is quite sensitive, it is critical to have a strong incident response capability in place.

Therefore, this document offers a solid approach towards managing cybersecurity-related events at FinSecure Ltd and mitigating associated risks.

Organisation Overview

FinSecure Ltd is an organization offering services in the FinTech industry that specializes in offering secure financial transactions over the internet to its individual customers and business clients. This organization allows its customers to carry out their financial transactions over the Internet and also helps them manage their accounts through the web and cloud hosting environment.

The operation of FinSecure Ltd involves the collection, storage, and management of very confidential and sensitive data, such as personal information, customer financial data, and transaction details. These data play a significant role in the operations of this organization and must be well protected since they are highly confidential.

This organization uses cloud infrastructure to support many other processes in the organization, such as payment systems, customer information system, employees' endpoint system, and the communication system for staff members. This cloud infrastructure creates a unique set of security issues for this organization.

The company FinSecure Ltd operates in an environment that requires it to be regulated because of the nature of the services provided by it and also because of the confidential nature of the data it deals with. FinSecure Ltd should be compliant with GDPR and also follows other industry standards concerning the security of information.

In such an environment, good governance, risk management, and cyber incident response are necessary to ensure the confidentiality, integrity, and availability of critical information systems. This document provides guidelines for responding to cyber incidents faced by FinSecure Ltd, especially in cases related to phishing attacks.

Purpose & Scope

Purpose

The objective of this Cyber Incident Response Plan is to provide an organized and consistent framework for the detection, management, and handling of cybersecurity incidents within FinSecure Ltd.

This plan outlines procedures and steps that need to be followed in order to make sure that cybersecurity incidents are:

- Timely identified and reported
- Analyzed and evaluated for their impact and significance
- Containment efforts initiated in order to mitigate damages
- Eradicated by taking remedial measures
- Recovery performed effectively and quickly

The plan aims at minimizing the adverse effects of cyber incidents on organizational operations, costs, and reputation, while maintaining compliance with applicable regulations such as GDPR.

Scope

This incident response plan covers all the systems, data, and assets that enable the functioning of FinSecure Ltd, especially those used to process, store, and transfer sensitive information.

The covered systems include the following:

Systems Involved

- **Email Systems**
  Internal and external email systems that serve as a common medium through which phishing and social engineering attacks can occur.
- **Endpoint Devices of Employees**
  These include employee laptops, desktops, and other devices used to access organisational systems and data.
- **Cloud-based Applications and Infrastructure**
  This comprises cloud infrastructure and applications that provide services related to payments processing and other operational activities of the organisation.
- **Customer Data Systems**
  These are the systems that handle sensitive data, including PII and financial data of customers.

Outside the Scope

Following items fall outside the scope of this plan:

- Physical security breaches (e.g., unauthorized access, theft of hardware)
- Vendor environments that are beyond control of FinSecure Ltd
- Legacy applications that do not support FinSecure's core payment processing operations

Definitions & Incident Classification

Key Definitions

In order to achieve a consistent interpretation throughout the organisation, the below key terms will be defined:

- **Cyber Event**
  A cyber event is an observable phenomenon occurring in a system or network that could potentially signal a security concern. A cyber event does not always cause a breach but could necessitate surveillance or further action.
  This includes anything from suspicious login attempts to system warnings or unusual email traffic.

- **Cyber Incident**
  A cyber incident is a confirmed phenomenon that poses a threat to or has the potential to compromise CIA of information systems or data. Incidents require response measures. These include activities like hacking, breaches, virus outbreaks, or outages.

- **Phishing Attack**
  A phishing attack is a social engineering tactic in which the attacker tries to manipulate a person into giving away confidential details, such as passwords or bank account numbers, by tricking them. It often takes place via false emails or other messages.

Incident Classification Levels

Cybersecurity events can be categorized depending on their **significance and possible impact on the company's operations**.

- **Low**
  This category covers insignificant events affecting only one user or device. The event does not involve any sensitive information and has no effect on the business.
  Example: Reporting suspicious email without any interaction with it.

- **Medium**
  Affecting several users or devices with possible exposure of non-critical information, but causing minimal disruption to normal operations.
  Example: Detection of malware in one end-point.

- **High**
  The event causes significant risk for the business since it can affect many devices, user accounts with high privileges, and involves sensitive data.
  Example: Compromising credentials via phishing results in an unauthorized intrusion.

- **Critical**
  Involving a very high risk since the event causes severe disruption to critical information systems and affects a considerable amount of sensitive information.
  Example: Breach of sensitive information or ransomware attack that impacts normal operations.

Incident Response Team (Roles & Responsibilities)

The success of an incident management system in FinSecure Ltd depends on having an

Incident Response Team (**IRT**) with well-defined roles and responsibilities. This team should be involved in coordinating all processes that relate to the detection, investigation, mitigation, and remediation of cyber incidents.

Incident Response Team Structure

The Incident Response Team consists of critical individuals drawn from various functions such as technical, operations, and governance.

Role	**Name**	**Key Responsibilities**
Incident Response Manager	Pruthviraj Patil	Overall responsibility for managing the incident response process. Coordinates response activities, makes critical decisions, ensures timely escalation, and communicates with senior stakeholders.
IT Security Analyst	Aarav Sharma	Responsible for monitoring alerts, analysing security events, investigating incidents, and identifying the root cause. Supports containment and eradication activities.
System Administrator	Oliver Bennett	Manages affected systems, applies patches, isolates compromised devices, and supports system recovery and restoration.
Legal & Compliance Officer	Amelia Clarke	Ensures compliance with regulatory requirements (e.g., GDPR), advises on legal implications, and supports breach notification processes where required.
Communications Lead	Riya Kapoor	Manages internal and external communications, prepares incident-related messaging, and coordinates stakeholder updates, including customers and regulatory bodies if necessary.

Roles & Responsibilities Overview

Incident Response Manager

- Manages the overall incident response process
- Reviews and approves containment and recovery actions
- Serves as the main liaison for escalations

IT Security Analyst

- Detects signs of system compromise
- Conducts forensic investigations
- Documents IOCs (Indicators of Compromise)

System Administrator

- Carries out containment tasks
- Performs recovery actions
- Applies security patches and configurations

Legal & Compliance Officer

- Evaluates legal implications of incidents
- Provides guidance on breach notification obligations
- Guarantees compliance with GDPR and internal guidelines

Communications Lead

- Controls communication during an incident
- Aligns messages with internal and external parties
- Maintains proper information dissemination

Escalation and Coordination

All the events will have to be notified to the Incident Response Manager, who will judge their seriousness and decide on the appropriate response to each incident. For high and critical incidents, the members of the Incident Response Team will work in close coordination.

Incident Scenario Description

Phishing Attack Leading to Credential Compromise

The above example is the description of a cyber-attack using phishing attacks on Finsecure Ltd, as one of the identified high-risk incidents that may pose a threat to Finsecure employees' credentials and systems' access.

An employee is targeted via an email that appears to come from a reliable internal or external entity of Finsecure Ltd. This email is crafted to make the employee take immediate action through the need to verify account information or change password credentials. Such email usually features a link directing the recipient to an authentic-looking login page.

In response to the phishing email, an unsuspecting employee ends up submitting their account credentials on the hacker's interface, leading to unauthorized account access by the hacker.

The attacker may engage in additional nefarious actions following the compromise, such as lateral movement, accessing data, or attempting privilege escalation. The security breach would be detected by observing abnormal behaviour, such as logins from unknown locations, abnormal access attempts, or deviation from typical user behaviour patterns.

This security event is plausible and impactful for FinSecure Ltd considering the company's dependence on cloud systems and the processing of confidential financial and personal information. This incident demonstrates the inadequacies in existing controls, which include sporadic use of multi-factor authentication (MFA), inadequate end-user knowledge, and poor monitoring capabilities.

Incident Detection & Identification

It is vital to effectively detect and recognise any cyber incidents to mitigate possible harm and ensure a swift response to the problem. For example, at FinSecure Ltd, any incidents related to phishing can be discovered with the help of user reporting, system monitoring, and security logging.

In the case in question, the incident could be first noted by a user who reported some irregularities with their communication with other users or abnormal account activity. Meanwhile, automated detection tools and security logging could reveal anomalies in the system such as unusual login attempts from unusual locations or abnormal account activity.

Signs that should alert us about the possibility of cyber-attacks include:

Login attempts from unusual IP addresses that were never used before.

Multiple unsuccessful logins attempt with a sudden and unexpected successful one.

Abnormal account activity during times when nobody normally uses the account.

Communication problems with other accounts such as the reception of suspicious emails.

If any of these signs are detected, the event is escalated and validated to confirm its status as a cyber-attack incident.

Incident Analysis

After detecting and validating the occurrence of the breach, there will be a thorough analysis carried out with regard to the nature of the problem, its possible implications, and its actual causes. This stage is very important in making an assessment of the whole situation and helping the Incident Response Team to make necessary decisions.

At this point, one can say that there is an evaluation of the authentication logs, system access logs, and any other activities that might have been done by unauthorised users.

Compromised Systems

The compromised user accounts offer unauthorized access to various systems of FinSecure Ltd, based on the privileges of the user. Systems that may be compromised by the attacker include the following:

- **Corporate Email System** – main entry into the network and source of initial compromise
- **Cloud Computing Solutions and Services** – accessed using single sign-on (SSO)
- **Customer Data Systems** – customer information databases
- **Collaboration Systems** – used for internal business purposes

Exposure of various systems will be established on the basis of user account privileges.

Possible Data Leakage

In light of the operating environment of the company, the security breach can lead to a data leakage, which will involve:

- **Personally Identifiable Information (PII)**
- **Client financial information and transactions details**
- **Corporate business and operation data**

The magnitude of data leakage is determined by reviewing access logs, data access activity, and any possible exfiltration of data.

Root Cause Analysis

The root cause of this incident can be traced back to a successful phishing attack that caused credentials theft. The success of this attack is due to pre-existing weaknesses found in the existing control environment in the security domain, which include:

- **The inconsistent deployment of multi-factor authentication (MFA)** among other types of controls, especially regarding user and privileged accounts
- **Lack of user training and presence of phishing simulations**
- **Poor monitoring**, such as lack of centralized logging and alerting systems

Such weaknesses made it possible to steal credentials and delay detection of any suspicious activities.

Incident Response Process

The incident response mechanism at FinSecure Ltd adopts a highly methodical approach whereby the incidents are effectively managed, including containment, eradication, and resolution of the issues without disrupting the firm's operations. This response strategy conforms to industry standards and aims to cater for technical and organizational components of the issue.

Containment

The primary goal of the containment stage is to minimize the damage caused by the event and avoid additional attacks from the attacker.

In case the credentials have been compromised, it will be necessary to isolate and secure both the compromised credentials and systems that are connected with them. In order to prevent further unauthorized access, the attacker will be prevented from using the credentials through disabling them.

All active sessions related to the compromised credentials should be terminated to prevent unauthorized activities within the organization.

To mitigate further risks, IP addresses can be blocked at the network level in case of an analysis revealing such a threat. Any other endpoints or systems that were used by the attacker need to be isolated from the network to avoid further spread of the attack.

Eradication

The phase of eradication concentrates on eliminating the cause of the breach from the environment and getting rid of any presence of malicious activity in the environment.

All affected credentials are re-set and protected through the imposition of good passwords and multi-factor authentication (MFA) where appropriate. All malicious sessions or configurations that have been set up by the attacker are detected and destroyed.

An extensive inspection of all affected devices is carried out to ensure there is no presence of malware in the environment. This could entail checking for any backdoor or persistence mechanisms that might be present.

Any vulnerabilities or weaknesses exploited by the attacker are addressed through patching or implementing new configurations.

Recovery

In this phase, the aim is to restore operations back to normal in a safe and secure manner.

Only once suitable security precautions are taken – such as password change and implementation of MFA – can the affected account be accessed. The systems would be progressively connected to the network upon successful validation of their integrity.

Further monitoring will be performed in order to identify any indication of further malicious acts. This could involve looking at the log files and examining any behaviour of users.

Recovery would be handled in a manner to ensure business continuity with security being assured.

Post-Incident Actions

After solving the incident, a review process is done in order to determine **lessons learnt and areas of improvement.**

The members of the Incident Response Team document the whole process by writing about the sequence of events and the measures taken to handle the problem. This helps the organisation to learn from the process and improve on their capabilities in handling any other incident.

From the review, it was recommended that the following should be **improved in terms of controls**:

- Stronger authentication processes, such as MFA
- User education through training and simulations
- Centralized logging and monitoring systems
- Incident detection and response process improvements

These recommendations will be used to update our policies and procedures in order to prevent further risks from happening.

Impact Assessment (Confidentiality, Integrity, Availability)

The effects of the incident are measured using the CIA (Confidentiality, Integrity, Availability) model, which considers the potential impact on the information security of FinSecure Ltd. The CIA model serves as the basis for decision-making regarding the priority of action.

Confidentiality – High Impact

The risk involved in terms of **confidentiality is relatively high**, considering that the access has been gained using compromised credentials. Since the nature of FinSecure Ltd's activities involves handling **confidential data**, there is every chance that the compromised credentials will offer access to personally identifiable information (PII), financial data, and even internal company data.

If this happens, FinSecure will have to face **non-compliance issues** based on GDPR guidelines, along with reputation damage and customer mistrust. The possibility of data being exposed can be said to pose a threat to confidentiality, even without confirming whether the data was exfiltrated.

Integrity - Medium Impact

The threat posed to the integrity of the data is considered to have a **medium impact** level because there might be an opportunity for the perpetrator to manipulate or alter the data available in the systems.

Nevertheless, at the moment of conducting the assessment, there was no proven instance of manipulation or alteration of the information or transactions in the systems. Even though it is possible to do so based on the level of access gained, the lack of proven cases suggests that the threat has a medium impact level.

Impact on Availability – Minor

Availability impact is **minor** because the problem does not affect system availability. This means that business processes will not be affected; for example, the processing of payments should not be hindered.

The temporary outage might occur only during the containment phase when the accounts or systems are put on hold. The duration of such an outage will be short-lived and under control.

Summary

Security Objective	**Impact Level**	**Justification**
Confidentiality	High	Risk of unauthorised access to sensitive PII and financial data
Integrity	Medium	Potential for data modification, no confirmed widespread impact
Availability	Low	No significant disruption to systems or operations

Incident Timeline

The sequence of events leading up to the security breach and ending with its containment is recorded in great detail. This helps in conducting a proper investigation of the situation.

Time	**Event Description**
09:00	Phishing email received by employee, appearing to originate from a trusted internal or third-party source.
09:12	Employee interacts with the email and clicks on the embedded malicious link.
09:14	Employee submits login credentials on a spoofed authentication page controlled by the attacker.
09:45	Attacker initiates unauthorised login using compromised credentials from an unfamiliar IP address/location.
09:50	Multiple authentication attempts observed, including successful login following prior failed attempts
10:00	Suspicious login activity flagged through log review and anomaly detection mechanisms.
10:05	Employee reports unusual account behaviour, including unexpected prompts and access activity.
10:10	Incident escalated to the Incident Response Team for investigation and validation.
10:20	Compromised account identified and **immediately disabled**; active sessions terminated.
10:30	Malicious IP address blocked at network level; containment actions implemented.
10:45	Initial assessment completed, confirming credential compromise and potential system exposure.

Communication Plan

Good communication is essential to facilitate **coordination, accuracy, and efficiency in dealing with any cyber-attacks**. FinSecure Limited maintains an organized approach to communication to ensure that all parties involved are kept abreast of the situation.

Communication Objectives

- **Update stakeholders** with up-to-date information
- **Maintain consistency** in communication throughout the organization
- Help **decision-making** in case of an incident
- **Comply with legal requirements** for notifications, such as GDPR
- Limit **damage to reputation** and preserve customer confidence

Internal Communication

The internal communications process is facilitated by the **Incident Response Manager** working with the Communications Lead to provide an effective control of information.

Main stakeholders for internal communications are:

- **IT Security Team / Incident Response Team**
  Receive current updates regarding the state of the incident and activities related to it
  Facilitate technical analysis and recovery
- **Management**
  Receive strategic-level briefings regarding the impact of the incident
  Help with the decision-making process and allocate resources
- **Affected Business Units**
  Notified in case of any effect on their operation
  Guidance provided regarding actions to take

All internal communications should be done using **official channels only**.

External Communication

External communications are strictly managed and made at appropriate times, considering the severity and consequences of the incident.

- **Customers (as applicable)**
  Will be informed if there is an actual or possible data exposure incident involving their personal or financial information
  Given instructions regarding protection measures such as resetting passwords, among other

- **Regulatory Bodies (GDPR Requirements)**
  If there is any data breach involving personal information, notification will be provided to the relevant regulatory body (for example, ICO) within 72 hours, following GDPR requirements Information regarding the data breach, its consequences, and any action being done to minimize damage will be provided.

- **Third Parties, (if applicable)**
  May include law enforcement, third-party vendors, or cybersecurity support organisations

External communications will be vetted and approved by the Legal & Compliance Officer and the Communications Lead prior to publication.

Communication Control and Governance

- Only **authorised individuals** are allowed to correspond externally concerning the incident.
- Correspondence should be **accurate, consistent, and authorised** before being sent.
- Sensitive information will only be shared on a **'need to know' basis**.
- Records will be kept of all correspondence for **auditing purposes**.

Risk Mapping and Alignment

In fact, this incident can be mapped directly to the IT Risk Assessment that was conducted before. In this way, there will be proper coordination between potential risks, control deficiencies, and actual incidents. In other words, incident management will be based on an organization's existing risk status.

Risk Alignment

The phishing threat that is reported herein falls under the following identified risk of FinSecure Ltd:

- **Risk ID:** R2
- **Risk Description:** Phishing attack against employees
- **Risk Severity:** High
- **Risk Score**: 9 (High Probability × High Consequences)

This risk was earlier identified by the company as one of its greatest risks because of the **frequency of phishing incidents and their dependency on the end-user's actions through emails.**

Control Gap Mapping

The effectiveness of the attack can be attributed to the **control weaknesses** previously highlighted. This reinforces the significance of the control weaknesses and their impact on the security posture of the organisation:

- **Inconsistency in implementing Multi-Factor Authentication (MFA)**
  Increased chances of an attack succeeding once credentials were compromised
- **Insufficient user education and security training**
  Decreased chances of the individual detecting the attack
- **Lack of monitoring and auditing of security controls**
  Delayed detection of any unauthorised activity

This further emphasizes the need for preventative and detective controls in lowering overall risk exposure.

Risk and Incident Integration

The occurrence highlights how a risk, which has been identified, can turn out to be an actual security threat if it is not appropriately managed using adequate controls. The relationship between the risk and the incident highlights the following:

- Verification of the **risk assessment approach**
- Impact of control **weaknesses in reality**
- Areas that need **urgent improvements**

After the occurrence, it will be necessary to **revisit and review** the risk related to phishing (R2), and update the risk register of the organization accordingly.

Continuous Improvement

The inclusion of the results of the incident response within the risk management cycle allows for **continuous improvement**. Lessons from this incident include:

- Improvement of current controls
- Risk rating and risk treatment strategy updates
- Resilience of the organization to future similar incidents

Recommendations and Control Improvements

Recommendations have been formulated based on the above analysis of the incident and the control deficiencies highlighted previously. The following recommendations will help improve the security position of FinSecure Ltd to mitigate the risk of occurrence of any similar incidents in the future.

Improving Authentication Measures

- Deploy **multi-factor authentication (MFA)** for all systems, including cloud-based applications, emails, and accounts that hold privileges.
- Adopt **strict password policies** and conduct regular reviews of credentials
- Enforce **principle of least privilege (PoLP)**

Such practices will greatly diminish the chance of an account being compromised by cybercriminals leading to unauthorised access.

Increasing Security Awareness among Users

- Institute a **continuous training program in security** matters for all users within the organisation
- Hold **phishing simulations** regularly to evaluate the ability of users to handle such situations
- Training on detecting malicious emails

Security awareness helps to minimise phishing attacks.

Monitoring and Detection Enhancements

- Develop a **SIEM** system for collecting and analysing security events
- Deploy **real-time alerting** to detect any unusual activities, including abnormal login practices
- Develop and maintain use **cases and detection rules** based on identified risks

With improved monitoring, detection, and incident response become faster and less harmful to the company.

Enhancing the Incident Response and Governance

- Define and review the **Incident Response Plan** on a regular basis
- Train employees on **incident management through simulation and tabletop exercises**
- Document incidents and maintain logs

This helps ensure that a company will be ready to manage future incidents.

Continuous Improvement and Risk Management

- Update the **risk register** with the results of incidents and adjusted risk ratings
- Evaluate security controls and **perform security assessments**
- Map existing controls against best practices defined in international standards such as **ISO 27001 and NIST Cybersecurity Framework**

Continuous evaluation and improvement are essential to maintaining an effective security posture in a dynamic threat environment.

Lessons Learned

The situation serves as an example of how important it is to consider **human factors** in cybersecurity because users are still the main channel through which hackers use phishing as a means of attacking an enterprise. In spite of basic safeguards being in place, a lack of consistent **security awareness** and reinforcement made the successful compromise of login credentials more likely. It is necessary to cultivate a security culture within the enterprise that relies on user training and regular phishing tests.

The reaction also reveals **delayed detection** as the reason for the delay because there were no proper tools for monitoring network traffic and alerting employees. Consequently, the attack could have gone unnoticed for longer than was ideal. It is important to enhance **detective controls** through centralised monitoring and clear definitions of alerts for future threats.

Moreover, the case proved that the success rate of **implementing security controls largely depends on the effective and continuous implementation of the said controls**. The lack of proper implementation of MFA served as one of the factors that contributed to the attack, since there was an easy entry point after compromising the credentials. Thus, it can be seen that there is a necessity of having a proper implementation framework as well as continuous validation of control implementation.

Besides, it is evident from the attack that it is vital to adopt a **layered security framework** to address cyber-attacks, which include preventive, detective, and reactive controls.

In general, all that has been learned through this case should become an integral part of the company's **risk management** and security strategy, allowing for constant improvements to be made regarding the control, process, and capability aspects. This will ensure that FinSecure Ltd is more resilient against any future cyber-attacks.

Compliance & Framework Alignment

The method of incident response outlined in this document complies with accepted standards and best practice guidelines, thus making it an effective process of responding to cybersecurity breaches in Finsecure Ltd.

ISO/IEC 27001

The processes mentioned above meet some important requirements of ISO/IEC 27001, especially with regard to incident management and control implementation. The actions taken are consistent with such control as outlined in Annex A that covers such areas as access control, incident response, and monitoring. The importance of documentation and continuous improvement is critical for ISMS implementation.

NIST Incident Response Lifecycle

The steps to follow during an incident response process include those described in the **NIST Cybersecurity Framework and the NIST SP 800-61**, which involve:

- Detection and analysis
- Containment
- Remediation
- Recovery
- Post-incident activity

This life cycle approach to the handling of computer security incidents is critical for a consistent and effective process.

General Data Protection Regulation (GDPR)

Taking into consideration the nature of the services offered by FinSecure Ltd, the proposed response plan has included the necessary components of **GDPR**. The important elements include:

- Identification and assessment of the risk of personal data breaches
- Effective measures for containment and reduction of the exposure of data
- Reporting to the concerned supervisory authority (like ICO) within **72 hours**, if needed
- Effective communication to those who are affected by the data breach

These elements will ensure that the organization is fulfilling its legal responsibilities.

Summary

The alignment of this response plan to ISO 27001, NIST, and GDPR will ensure that FinSecure Ltd **follows a well-coordinated framework** in responding to cyber security incidents as well as adhering to regulations within the process.

Appendices

Appendix A – Incident Log Template

Date	Time	Action Taken	Description	Owner	Status
21/04/2026	10:00	Incident Detected	Suspicious login identified	IT Security Analyst	Open
21/04/2026	10:21	Account Disabled	Compromised account locked	System Admin	Completed
21/04/2026	10:35	IP Blocked	Malicious IP blocked	IT Security Analyst	Completed

Appendix B – Evidence Register

Evidence ID	Description	Source	Collected By	Date/Time	Storage Location
EV-001	Login logs	SIEM / Logs	IT Security Analyst	21/04/2026 10:10	Secure Server
EV-002	Phishing email copy	Email system	Analyst	21/04/2026 10:05	Evidence Folder
EV-003	IP activity logs	Firewall	Analyst	21/04/2026 10:15	Log Archive

Appendix C – Incident Response Checklist

Phase	Action Item	Description	Status (YES/NO)	Owner
Detection & Identification	Identify suspicious activity	Monitor alerts, logs, or user reports		IT Security Analyst
	Validate incident	Confirm whether event is a security incident		IT Security Analyst
	Escalate incident	Notify Incident Response Manager		IT Security Analyst
Containment	Disable compromised account	Prevent further unauthorised access		System Administrator
	Terminate active sessions	Log out all active sessions		System Administrator
	Block malicious IP	Restrict attacker access at network level		IT Security Analyst
	Isolate affected systems	Prevent lateral movement		System Administrator
Eradication	Reset credentials	Enforce password reset and MFA		System Administrator
	Remove unauthorised access	Revoke tokens, sessions, permissions		IT Security Analyst
	Scan systems	Perform malware and integrity checks		IT Security Analyst
	Apply fixes	Patch vulnerabilities and update configs		System Administrator
Recovery	Restore access	Safely re-enable user/system access		System Administrator
	Validate system integrity	Confirm systems are secure and stable		IT Security Analyst
	Monitor activity	Watch for recurring suspicious behaviour		IT Security Analyst
Post-Incident	Document incident	Record timeline, actions, findings		Incident Response Manager
	Conduct review	Perform lessons learned analysis		Incident Response Team
	Update controls	Implement improvements and fixes		IT Security / GRC Team
	Update risk register	Reflect new risk insights		GRC Analyst